Lyne: data security and data protection overview

Prepared: 11 November 2026, from the code on `staging` and the production configuration. **Owner:** Debra-Kaye Smith, DKS Technologies. **Status of this document:** every claim names the file or setting that makes it true. Where something is not true yet, it says so. Nothing here has been independently audited or certified.

Status markers used throughout:

Marker	Meaning
In place	Running in production today
Built, not yet live	Written and tested on `staging`; goes live when promoted to production (and, where noted, after a migration or server step the owner approves)
To do (product)	Software work not yet done
To do (owner)	A legal or organisational step only the business can take

1. Summary for a buyer

Lyne is a queue and service-flow platform. The organisation that licenses it decides which of its staff see what. Lyne's own role is to run the system safely and keep the organisation's data separate from every other organisation's.

- **Identification numbers stay on the phone.** TRN and national ID are read and stored only on the customer's device, in its secure keychain, and are never sent to Lyne. *(Built, not yet live: the last server path that could store them is removed on `staging`; see §4.1.)*
- **Every request is checked on the server.** Sign-in is verified with the identity provider on every protected request, then the organisation, facility, section and ticket are checked before any data is returned. *(In place.)*
- **Encrypted in transit and at rest.** HTTPS for all traffic, an encrypted and certificate-verified connection to the database, and provider encryption of the database disk. *(In place.)*
- **Backed up every night, with an encrypted copy off the server.** *(Nightly verified backups: in place. Encrypted off-site copy: built, not yet live; see §5.4.)*
- **Staff actions are recorded** in a tenant-scoped audit log. *(In place.)*
- **People can download and delete their data.** *(In place.)*

2. Jamaica Data Protection Act, 2020: where Lyne stands

The Act has been fully in force since 1 December 2023. It applies to any person who processes personal data in Jamaica. Its main duties, and Lyne's position on each:

2.1 Who is the controller

- For an organisation's **visit and queue records** (who was served, where, how long they waited), the **organisation** decides why the data is processed. It is the data controller, and DKS Technologies acts for it, as its processor.
- For **customer app accounts** (email, name, phone, saved organisations, notification settings), **DKS Technologies** decides why the data is processed, so it is the data controller.

Both roles carry duties. The organisation's contract with Lyne should say which is which; see §7.

2.2 The eight data protection standards

#	Standard	What Lyne does	Status
1	Fair and lawful processing	Published privacy policy (`legal/PRIVACY_POLICY.md`); consent captured for SMS (`sms_consent` on walk-ins, `apps/backend/src/routes/tickets.js`)	In place
2	Purpose limitation	Data is used to run the line and report on service, as the policy states. No advertising, no sale of data, no trackers (`apps/website` cookie notice; no analytics SDK in the apps)	In place
3	Data minimisation	No TRN, national ID or passport number on the server; walk-in phone and date of birth are optional fields (`tickets.js`, walk-in schema); transfer notes are staff-only and never shown to the patient (migration 049)	In place, plus 4.1 built, not yet live
4	Accuracy	Customers edit their own profile (`PATCH /api/auth/profile`); staff correct visit outcomes with a reason	In place
5	Storage limitation	`apps/backend/src/jobs/retention.js` enforces the policy's periods: visits anonymised after 24 months, audit log 12 months, intake forms 24 months. On by default (`RETENTION_ENABLED`, `deploy/docker-compose.prod.yml`)	In place
6	Data subject rights	Download my data (`GET /api/auth/export`), delete my account (`DELETE /api/auth/account`, which removes the person and strips identity from kept visit records), correct my details; access requests answered instantly by the app, inside the Act's 30 days	In place
7	Security (technical and organisational measures)	See §3 to §5	Mostly in place; gaps in §8
8	Transfers outside Jamaica	Hosting is in the United States (DigitalOcean, Supabase). The policy discloses this and relies on consent and contractual safeguards (`legal/PRIVACY_POLICY.md` §7). The Act has no data-localisation requirement.	In place for app users; organisations need it in their contract (§7)

2.3 Other duties under the Act

Duty	What it requires	Status
Registration with the Information Commissioner	Register before processing, pay the registration and annual fee	**To do (owner).** The privacy policy still shows `[REGISTRATION NUMBER]`

Duty	What it requires	Status
Data Protection Officer	Required for public authorities, for large-scale processing, and for processing **sensitive personal data**, which includes health information	**To do (owner).** The privacy policy says a DPO is "not currently required". That stops being true once hospitals use triage answers and "possibly urgent" flags, which are health information. Appoint one and publish their contact details.
Annual Data Protection Impact Assessment	Submit to the Commissioner within 90 days after each calendar year ends	**To do (owner).** The first one is due by 31 March 2027. This document and §6 are its technical half.
Breach notification	Tell the Commissioner, and affected people, within 72 hours of becoming aware: what happened, its scale, the mitigation, the consequences, and the DPO's contact	**To do (owner and product).** The policy promises notification. A written incident procedure and breach register are needed (§8).
Records of processing	Keep records of what is processed and why	**To do (owner).** §6 is a starting point.

Sources: the Office of the Information Commissioner's summary of controllers' obligations (oic.gov.jm), and the Chambers *Data Protection & Privacy 2026: Jamaica* practice guide. This is not legal advice. Have an attorney confirm it before relying on it in a contract.

---

3. Access control

Control	How	Where	Status
Verified sign-in	Every protected request carries a Supabase token, verified with Supabase before anything else runs	`apps/backend/src/middleware/auth.js`	In place
Roles	Executive (whole organisation), manager (one facility), supervisor (one section), line staff (own counter), kiosk (walk-in intake only)	`apps/backend/src/middleware/tenantAccess.js` (`requireStaffRole`)	In place
Tenant isolation	Organisation, facility, section, queue and ticket checked on the server for every request; the caller cannot widen their own scope	`tenantAccess.js`; tested in `apps/backend/test/tenant-isolation.test.js`, `role-escalation.test.js`	In place
Session limits and revocation	Revoked tokens rejected; concurrent sessions limited	`apps/backend/src/middleware/sessionLimiter.js`, `token_revocations` table	In place

Control	How	Where	Status
Rate limiting	Separate limits for sign-in, joining a line, public polling and general use, keyed on the signed-in person	`apps/backend/src/middleware/rateLimiter.js`	In place
Input validation	Every write validated against a schema; unknown fields stripped	`apps/backend/src/middleware/validate.js` (zod)	In place
Verification codes	Six-character code proves the right person is at the counter; never sent to staff screens; an end-to-end test fails on a leak	`e2e/api-leaks.spec.ts`	In place
Masked contact details	Phone numbers masked on case lists	`apps/backend/src/utils/maskData.js`	In place
Two-factor sign-in for staff	Not available	none	**To do (product)**; see §8

4. Personal data on the customer's phone

4.1 Identification numbers

- TRN and national ID are recognised on the phone (`apps/mobile/src/lib/trn.ts`) and kept in the device keychain (`apps/mobile/src/lib/documentVault.ts`, `expo-secure-store`). They are cleared on sign-out, and the customer can protect viewing them with fingerprint, face or passcode.
- Signup and profile updates do not accept them (`apps/backend/src/routes/auth.js`, `middleware/validate.js`).
- **Fixed on 11 November 2026 (built, not yet live):** an old server route, `/api/ocr`, was still available to any signed-in account and stored scanned TRN, national ID and passport numbers unmasked. No app used it. It is removed, and migration `database/migrations/050_remove_identity_numbers.sql` deletes the table and the old `users.trn` / `users.national_id` columns. A test (`apps/backend/test/no-identity-numbers.test.js`) fails if any of it returns. It goes live after a production deploy, then the migration, with a backup first.

4.2 Limits

A web browser has no secure device store, so the identification vault works only in the Android and iPhone apps.

5. Infrastructure

5.1 Encryption in transit

- Public traffic is HTTPS only, through Caddy with automatic certificates. HSTS is set for a year, including subdomains (`deploy/Caddyfile`).

- The API connects to the database over TLS with the provider's certificate verified (`MYSQL_SSL_CA`, `ssl-mode=VERIFY_CA`; `apps/backend/src/db/pool.js` refuses an unverified connection unless it is asked for by name).
- The database is on DigitalOcean's private network (VPC), not the public internet.

5.2 Encryption at rest

- DigitalOcean Managed MySQL encrypts its storage at rest with LUKS (DigitalOcean's managed-database security documentation and shared-responsibility model).
- Off-site backup copies are encrypted with AES-256 on the server before they leave it (`deploy/offsite-backup.sh`).

5.3 Server hardening

- The firewall allows only ports 22, 80 and 443. fail2ban and unattended security upgrades are on. SSH accepts keys only, with no root login (`deploy/provision.sh`).
- Security headers on every response (`helmet`, `apps/backend/src/index.js`), and a CORS allow-list of web origins (`ALLOWED_ORIGINS`).
- The application's database login is least-privilege: read and write rows only, no schema changes (`database/security/harden_database.sql`). Backups use their own read-only login.
- The Supabase service key never reaches a browser. A deploy check confirms it is absent from the admin bundle (`deploy/verify.sh`).
- Error reports to Sentry drop request bodies and strip identification numbers, tokens and keys (`apps/backend/src/lib/monitoring.js`).

5.4 Backups and recovery

	Status
Nightly backup at 02:15, verified by decompressing it and checking key tables; 14 days kept on the server (`deploy/backup-managed-db.sh`, cron)	In place
Restore rehearsed into a scratch database; passed 3 October 2026	In place
Encrypted copy off the server: AES-256 on the droplet, uploaded to DigitalOcean Spaces, size verified after upload, kept 90 days (`deploy/offsite-backup.sh`); `deploy/verify.sh` fails if the newest backup is not in the bucket	**Built, not yet live.** Needs a production deploy and a one-time setup step. Until then, backups exist only on the server.
Authentication accounts backed up by Supabase	In place

5.5 Audit trail

- Staff actions are written to `audit_logs`, scoped to the organisation (`apps/backend/src/middleware/auditLog.js`, migrations 002 and 005). It is used on 29 routes, including deletion, target changes (which need a reason), imports and exports.
- Every ticket state change is recorded in `queue_events`.
- Managers and executives can read their own organisation's audit log (`apps/backend/src/routes/audit.js`).
- The audit log is kept 12 months (`retention.js`).

5.6 Reliability of the line itself

Simultaneous joins can't produce duplicate places in line. A test against a real MySQL server fires 18 walk-ins from three clerks and 10 app joins at the same moment, five times over, and checks that places are exactly 1 to N with no duplicates or gaps (`apps/backend/test/db/walkin-concurrency.db.test.js`). That test found a real defect, and it was fixed on 11 November 2026 (`apps/backend/src/utils/ticketSlot.js`). *(Built, not yet live.)*

6. What personal data goes where

Service	What it receives	Where	Status
DigitalOcean	Everything Lyne holds: the API server and the database	United States	In place
Supabase	Sign-in email and password (hashed by Supabase); staff and customer authentication	United States (East)	In place
Resend	Email address and the content of sign-in and reset emails, sent through Supabase	United States	In place
Twilio	Phone number and the text of a queue update, when SMS is on and the person agreed	United States	**Off** (`SMS_ENABLED=false`)
Sentry	Error reports with bodies dropped and identifiers, tokens and keys stripped	United States	Only when a reporting key is set
Expo, Apple, Google	Push notification delivery: a device token and a notification that says only "Your queue update"	United States	When notifications are allowed
GoDaddy	The marketing website; the contact form's message	United States	In place

The privacy policy's sub-processor list (`legal/PRIVACY_POLICY.md` §7.2) **does not yet name Resend or Twilio.** To do (owner): add them.

7. Data ownership and organisations' data

	Status
Each organisation's data is separated by organisation in one database; the server enforces it on every request	In place
Supervisors and above can export visit timings as CSV, within their scope (`GET /api/analytics/export-csv`)	In place
Full export of everything one organisation holds (visits, tickets, staff actions, reports)	**To do (product)**; planned
Deletion of an organisation's data at contract end, with a certificate	**To do (product)**
A separate database per organisation, or hosting in the organisation's own environment	Not offered today; decision record planned
Data processing agreement (Lyne as processor, organisation as controller), listing sub-processors, the security measures above, breach notice to the organisation, and return or deletion at contract end	**To do (owner)**; needed for every contract

8. Gaps, in order of importance

1. **Register with the Information Commissioner, and appoint a Data Protection Officer** (owner). Hospitals bring health information, which makes a DPO a legal requirement.
2. **Go live with the fixes already built:** the TRN route removal and migration 050, encrypted off-site backups, and the walk-in numbering fix (owner approval, then deploy).
3. **Two-factor sign-in for staff.** The Act doesn't name it, but any bank or government security review will ask for it. Supabase supports authenticator-app codes (TOTP) at no extra cost. The plan is to require it on the server for executives, managers and supervisors, by checking the `aal2` claim in the sign-in token, with enrolment in the desktop admin; kiosk accounts are exempt.
4. **Incident response procedure and breach register,** to meet the 72-hour notification duty: who decides, who is told, a template notice for the Commissioner, and a log of every incident.
5. **Data processing agreement template** for organisations, and the sub-processor list completed (§6).
6. **Organisation-level export and contract-end deletion** (§7).
7. **First annual DPIA,** due by 31 March 2027.
8. **Company and insurance:** DKS Technologies is a sole trader with no cyber insurance (`legal/COMPLIANCE_NOTES.md`). Public-sector and bank procurement usually require both.
9. **Independent test:** no external penetration test or certification yet. The internal checklist is `docs/pre-launch-security-checklist.md`.

9. What Lyne should not claim yet

- "Two-factor authentication": not yet.
- "Off-site backups": only once the off-site step has run on production.
- "TRN never reaches our servers": true for the apps today; unconditionally true once migration 050 is applied.
- "Certified", "audited", "compliant with the Data Protection Act": not until registration, a DPO and an external review are in place. Say "built to the Act's standards" instead.